

Audit-Tail Final Report

Project: **vulnerable-invoice-service** · Stage 5 (aggregate) · Generated 2026-07-09T06:50:00Z · PR [#69](#) (`fix/depSCAN-20260709-062726` → `main`) · Source: `61ed8c3` · Health Score: **75 / 100** Grade B — minor issues (pending merge)

Executive summary

- **24** dependencies scanned · **68** CVEs · **3 CRITICAL / 1 HIGH / 3 MEDIUM** dependencies carried known CVEs.
- **Supply-chain:** typosquatted `com.fastxml.jackson.core:jackson-databind` **removed**; the plain-HTTP `internal-untrusted-mirror` repository declaration remains in `pom.xml` but is confirmed unused for resolution (non-blocking warning).
- **Licenses:** 1 violation (GPL-2.0-with-FOSS-exception on `mysql-connector-java`) — still unresolved.
- **Remediation:** consolidated PR #69 fixed/removed 5 of 7 candidates (typosquat removed; `log4j-core/api` → 2.25.4; `jackson-databind` → 2.18.8; `commons-io` → 2.14.0; `commons-lang3` → 3.18.0). 2 deferred to tracking issues: [#67](#) (guava, MAJOR_REVIEW) and [#68](#) (`mysql-connector-java`, INEFFECTIVE bump + license violation).
- **Latest gate outcome:** **BLOCK** on PR #69 until #68's HIGH CVE and license violation are actually resolved. Never auto-merged — a human must review.

Health score breakdown

State	Factor	Deduction
Baseline (<code>main</code> , pre-run)	3 unresolved CRITICAL (<code>log4j-core</code> , <code>jackson-databind</code> , <code>typosquat-override</code>) × −15	−45
	1 unresolved HIGH (<code>mysql-connector-java</code>) × −8	−8
	3 unresolved MEDIUM (<code>guava</code> , <code>commons-lang3</code> , <code>commons-io</code>) × −2	−6
	3 supply-chain BLOCK findings (<code>typosquat</code> + <code>untrusted-source</code> + GPL license) × −10	−30
	1 outdated-major dep (<code>guava</code>) × −3	−3
	Baseline score (floored at 0)	8 / 100
Current (PR #69 head)	0 unresolved CRITICAL	0
	1 unresolved HIGH (<code>mysql-connector-java</code> , bump ineffective) × −8	−8
	2 unresolved MEDIUM (<code>guava</code> ; residual <code>jackson-databind</code> CVE-2026-54515) × −2	−4
	1 supply-chain BLOCK finding (GPL license on <code>mysql-connector-java</code>) × −10	−10
	1 outdated-major dep (<code>guava</code> , deferred) × −3	−3
	Current score	75 / 100

The current score reflects **PR #69's branch**, not `main` — it only takes effect once the PR merges. **Projected after #68 lands** (`mysql-connector-java` migrated to `com.mysql:mysql-connector-j` and its CVE + license both clear): removes the remaining −8/−10 deductions → **~93/100 (Grade A)**, leaving only `guava`'s deferred major-version review (#67) outstanding.

Top risks (ranked, post-remediation state)

Coordinate	Risk	Band	Top CVE	Status
------------	------	------	---------	--------

mysql:mysql-connector-java:8.0.30	7.0	HIGH	CVE-2023-22102 (8.3)	Unresolved — bump ineffective, needs coordinate migration (#68)
com.google.guava:guava:24.1.1-jre	5.5	MEDIUM	CVE-2023-2976 (5.5)	Unresolved — deferred, major-version jump (#67)
com.fasterxml.jackson.core:jackson-databind:2.18.8	—	MEDIUM	CVE-2026-54515 (residual, no fix published yet)	Target CVE-2019-14379 cleared; new unrelated finding noted for awareness
org.apache.logging.log4j:log4j-core:2.25.4	—	OK	none	Fixed — Log4Shell cleared
commons-io / commons-lang3	—	OK	none	Fixed
com.fastxml.jackson.core:jackson-databind (typosquat)	—	OK	n/a	Removed

Remediation activity

Dependency	Change	CVEs cleared	Status
com.fastxml.jackson.core:jackson-databind (typosquat)	removed	n/a (supply-chain)	in PR #69
org.apache.logging.log4j:log4j-core / log4j-api	2.14.1 → 2.25.4	CVE-2021-44228, -45046	in PR #69
com.fasterxml.jackson.core:jackson-databind	2.9.8 → 2.18.8	CVE-2019-14379 + 44 related	in PR #69
commons-io	2.4 → 2.14.0	CVE-2021-29425	in PR #69
org.apache.commons:commons-lang3	3.4 → 3.18.0	CVE-2025-48924	in PR #69
com.google.guava:guava	unchanged	none	#67 (MAJOR_REVIEW)
mysql:mysql-connector-java	unchanged (bump reverted)	none	#68 (INEFFECTIVE)

Gate (Stage 4) — current verdict: BLOCK

Check	Result	Evidence
Unit tests (mvn test)	PASS	2/2 tests
OWASP CVE (0 CRITICAL/HIGH)	FAIL	mysql-connector-java CVE-2023-22102, HIGH (8.3), unresolved
Supply-chain audit	FAIL (BLOCK)	Same HIGH CVE + GPL-2.0 license violation, per depscan-supplychain-audit.json

mvn clean verify also fails on the pre-existing JaCoCo coverage gate (0.56 vs 0.80) — unrelated to this PR's dependency changes and **not** used as a gate blocker.

Required actions before re-gating:

1. Migrate mysql:mysql-connector-java → com.mysql:mysql-connector-j 8.2.0+ to actually clear CVE-2023-22102 and re-evaluate its license (#68).
2. Re-run Stage 4 once #68 lands.
3. Resolve #67 (guava major-version bump) on its own schedule — not a hard blocker for #69.

Trend vs. previous run

A prior audit-trail report exists (Generated 2026-06-10, before this repo's dependency set grew from 9 to 24 tracked coordinates), which recorded a baseline health score of **0/100 (Grade D)** with a *projected* post-merge score of ~88/100. This run supersedes it with live figures: baseline **8/100** → **current 75/100 (Δ +67)**, CVEs cleared this cycle: **CVE-2021-44228, -45046 (log4j)**, **CVE-2019-14379 + 44 related (jackson-databind)**, **CVE-2025-48924 (commons-lang3)**, **CVE-2021-29425 (commons-io)**, plus the typosquat removed. The dependency-set change means the two scores aren't a strict apples-to-apples diff, but the direction and magnitude of improvement are consistent with the prior run's projection.

Demo script (live readiness)

1. **Show a vulnerable project** — open `pom.xml` on `main`; point out the labeled `ISSUE #1 – #6` comment blocks (outdated deps, known CVEs, license violation, typosquat, untrusted repo, coverage gate).
2. **Detect** — `depscan-report.json` / `depscan-reports/CVE-Report.md` : 68 CVEs across 24 deps, typosquat + untrusted-repo alerts. (`/risk_scoring_agent <repo>`)
3. **Score** — `depscan-reports/Risk-Scoring-Report.md` : typosquat force-escalated to CRITICAL #1 despite carrying no CVSS score; log4j-core/jackson-databind next.
4. **Fix** — PR #69: 5 of 7 candidates fixed/removed on one consolidated branch; 2 deferred to tracking issues (#67, #68) rather than silently dropped.
5. **Gate & merge** — `/pr_validation_agent 69` : verdict BLOCK, with structured evidence (unresolved HIGH CVE + GPL violation on the untouched `mysql-connector-java`) — demonstrates the gate catches issues *outside* the PR's own diff, not just what it changed. A human still merges once #68 clears.
6. **Prove** — re-render this report: health score 8 → 75 now, projected ~93 once #68 lands.

Pre-flight checklist: `git` + Maven + Java 17 on PATH; Syft/Grype installed (OWASP Dependency-Check's NVD sync is infeasible without a warm DB/API key — use Syft+Grype cross-confirmed against live NVD REST as the substitute); `GITHUB_TOKEN` /GitHub MCP credentials valid; repo at commit `61ed8c3` .

Rollback note: to reset the demo, delete branch `fix/depscan-20260709-062726` , close PR #69 and issues #67/#68 (or leave them as historical examples), and re-run the pipeline from `main` at `61ed8c3` .

State of supply-chain hygiene (stakeholder summary): The pipeline took this deliberately-vulnerable service from a health score of 8/100 (three CRITICAL CVE families, a typosquatted dependency, and a GPL license violation) to 75/100 in one automated run, clearing Log4Shell and the jackson-databind deserialization CVEs and removing the supply-chain impersonation risk — all without a human touching `pom.xml` . The merge gate correctly held the line on the one dependency (`mysql-connector-java`) where a simple version bump could not actually clear its CVE, routing it to a tracked follow-up instead of a false-positive "fixed."

Aggregated from `depscan-report.json` , `depscan-risk-report.json` , and `depscan-supplychain-audit.json` . Generated by the Dependency & Supply-Chain Plugin — Stage 5.